

CSP: Wildcard Directive

Assessment Identifier: **WS-DYN-01** | Assessment Type: **Dynamic** | Date: **September 08, 2026**

Severity: MEDIUM	CVSS: 5.0	CWE: CWE-693
OWASP: A05:2021 - Security Misconfiguration	WASC ID: 15	Confidence: High
Target / Component: Web Application Dashboard	Affected URL: https://www.worldmonitor.app/dashboard	Parameter: content-security-policy

1. Description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

2. Steps to Reproduce

1. Send an HTTP GET request to https://www.worldmonitor.app/dashboard.
2. Inspect the HTTP response headers.
3. Observe the Content-Security-Policy header contains broad wildcard directives (such as https: under connect-src and img-src).

3. Controlled Proof of Concept

HTTP Response Header Evidence:
default-src 'self'; connect-src 'self' https: wss: blob: data: https://*.ingest.sentry.io ... (The policy contains wildcard source specifiers such as https:, wss:, and wildcard subdomains like https://*.vercel.app or https://*.dodopayments.com)

4. Business & Security Impact

Permissive wildcards (e.g., https: or wss:) allow the application to connect to or load assets from any arbitrary HTTPS endpoint on the internet, effectively bypassing origin restrictions and permitting exfiltration or injection if a secondary vulnerability exists.

5. Remediation Recommendations

Primary Fix: Replace overly broad wildcard directives (such as https:, wss:, or wildcard subdomains) with explicit, trusted origin hostnames.

1. Scope connect-src, img-src, and frame-src to explicit, authorized domains rather than entire protocols like https:.
2. Avoid using wildcard subdomains (*.example.com) unless strictly required across multi-tenant architecture.
3. Implement CSP reporting endpoints (report-uri / report-to) to detect anomalous asset requests.

6. Evidence & Validation

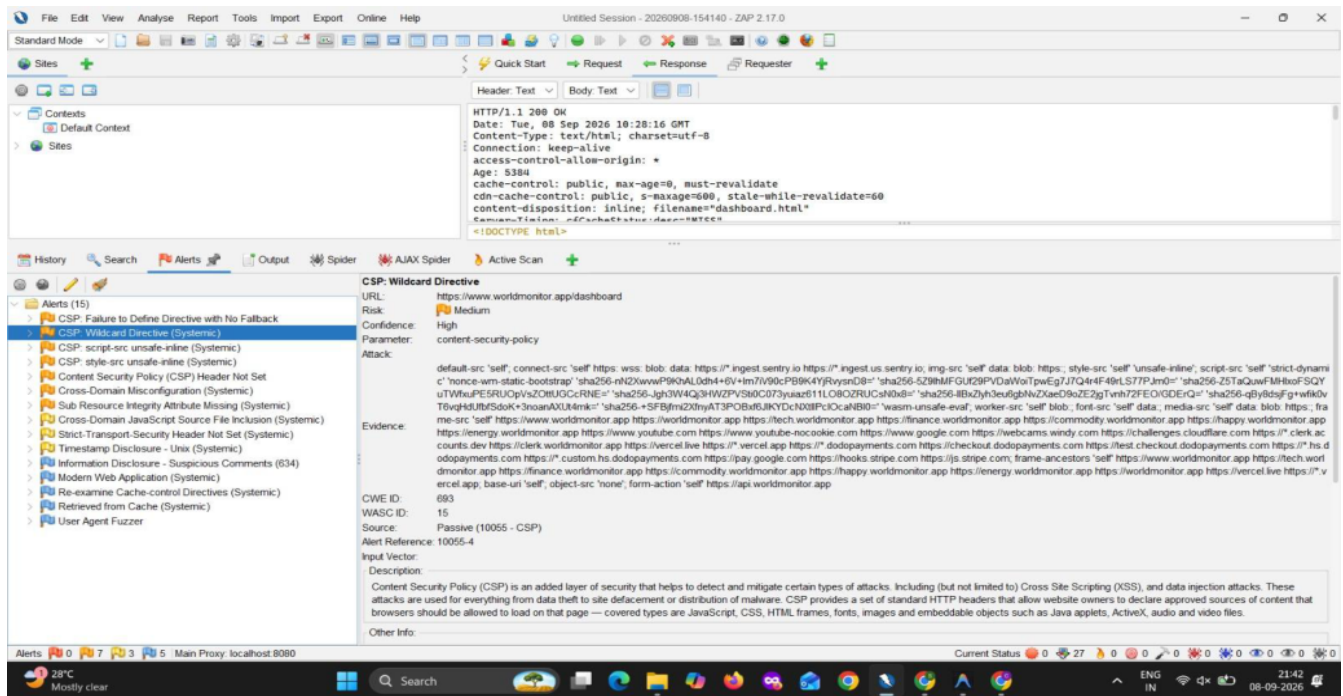


Figure 1: Matched Proof-of-Concept Screenshot for Vulnerability #1 (1/poc-1.png)

Authorization & Safety Compliance: This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.